

Literature Review

Sanjay M

25PG00181

Paper 1

Title: *Zero Trust Architecture*

Authors: Scott Rose, Oliver Borchert, Stu Mitchell, Sean Connelly

Publication: NIST Special Publication (SP) 800-207

Publisher: National Institute of Standards and Technology (NIST)

Paper Link: [Official NIST Paper PDF](#)

Published: August 2020

Review:

In this paper, the authors addressed the problem that **traditional perimeter-based security is not suitable for modern environments** involving cloud services, remote users, mobile devices, and distributed resources. They proposed a **Zero Trust Architecture (ZTA)** based on the principle that no user, device, or resource should be automatically trusted based only on its network location. The architecture focuses on **identity-based access control, continuous verification, least-privilege access, policy decision and enforcement points, identity management, and monitoring**. The authors describe different Zero Trust approaches including **enhanced identity governance, micro-segmentation, and software-defined perimeter/network-based approaches**, along with a **trust algorithm** that uses information such as user identity, device status, roles, access requests, historical behaviour, and threat intelligence to make access decisions. The document also discusses how Zero Trust can be applied to **cloud and multi-cloud environments**, enterprise services, and different deployment models. The results of the work are mainly a **common conceptual architecture, components, deployment models, and security principles** that organizations can use when designing and implementing Zero Trust rather than numerical experimental results. The authors also identified challenges such as **compromising the policy engine or policy administrator, denial-of-service against policy components, stolen credentials, limited visibility, and risks from automated software agents making security decisions**. Therefore, this work provides the **foundation for the identity-centric access control, policy enforcement, continuous verification, monitoring, and cloud security components** planned in your ZeroTrustCloud project.

Paper 2

Title: *A Zero-Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Location Environments*

Authors: Ramaswamy Chandramouli, Zack Butcher

Publication: NIST Special Publication (SP) 800-207A

Publisher: National Institute of Standards and Technology (NIST)

Paper Link: [Official NIST Paper PDF](#)

Published: September 2023

Review:

In this paper, the authors addressed the problem of **implementing Zero Trust access control in cloud-native applications** that use microservices and operate across multiple cloud and on-premises environments. They proposed a **Zero Trust Architecture model based on identity-centric and multi-tier access policies**, where access decisions are not based only on network location but also on the identity of users and services. The approach uses **service mesh, sidecar proxies, ingress and egress gateways, SPIFFE-based workload identities, mTLS, IAM, authentication, authorization, and policy enforcement** to secure communication between cloud-native services. The authors considered an environment containing **microservices deployed across multiple clusters, multiple clouds, and on-premises infrastructure**, with a service mesh used to manage communication and security policies. The proposed model combines **network-tier policies and identity-tier policies**, allowing organizations to apply fine-grained access control based on service identity and application-level actions. The authors also explain how identity-tier policies can support **policy as code, automated policy testing, consistent policies across different environments, and fine-grained service-to-service authorization**. The results of the work are mainly a **reference architecture, policy framework, implementation approach, and example policies** for applying Zero Trust principles to cloud-native applications rather than numerical experimental results. The authors identified limitations such as the difficulty of using purely identity-based policies in hybrid environments, administration challenges for service identities, and the continuing need for some network-level policies because of compliance requirements. Therefore, this paper is **highly relevant to the ZeroTrustCloud project** because it directly supports the project's planned use of **identity-centric access control, Kubernetes/cloud-native environments, service mesh security, mTLS, policy-as-code, continuous monitoring, and multi-cloud Zero Trust policy enforcement**.

Paper 3

Title: *Zero-Trust Access Management Models for Securing Cloud-Native Applications*

Authors: Sandeep Dommari

Publication: International Journal of Applied Mathematics, Volume 38, No. 11s

Publisher: International Journal of Applied Mathematics

Paper Link: [Official Research Paper – International Journal of Applied Mathematics](#)

Published: 2025

Review:

In this paper, the author addressed the problem of **making real-time least-privilege access decisions in zero-trust cloud-native environments**, where user identity, context, and audit information must be evaluated quickly. The paper proposed an **uncertainty-aware zero-trust access decision framework** for Kubernetes environments using machine learning models along with Open Policy Agent (OPA) rules. The approach uses **FT-Transformer with graph features, XGBoost, OPA policies, probability calibration, temporal validation, and leave-site-out testing**. The study used the **CNAM-Access-2025 dataset**, containing authenticated access requests and Kubernetes/cloud IAM-related logs from multiple sites in the EU and US. The data was divided using **time-based splits with a seven-day embargo** to reduce data leakage, and the models were evaluated using AUPRC, AUROC, calibration error, latency, and throughput. The FT-Transformer Graph achieved an **AUPRC of 0.61, AUROC of 0.96, and 5.90% false-positive rate at 99% TPR**, performing better than XGBoost, FT-Transformer Tabular, and OPA rules. It also achieved **9.3 ms p95 latency and around 3400 requests per second**, showing that the approach can support real-time access decisions. However, the author identified limitations such as dependence on **Kubernetes audit and IAM logs, limited network and content information, possible remaining data leakage, cross-site generalization issues, concept drift, and limited interpretability**. Therefore, this paper is **highly relevant to the ZeroTrustCloud project** because it supports the project's planned use of **identity-based access control, least-privilege enforcement, Kubernetes/cloud-native security, OPA policy enforcement, continuous monitoring, and automated access decisions**.

Paper 4

Title: *Security of Zero Trust Networks in Cloud Computing: A Comparative Review*

Authors: Sirshak Sarkar, Gaurav Choudhary, Shishir Kumar Shandilya, Azath Hussain, Hwankuk Kim

Publication: *Sustainability*, Volume 14, Article 11213

Publisher: MDPI

Paper Link: [Official Research Paper – MDPI](#)

Published: 7 September 2022

Review:

In this paper, the authors addressed the problem of **securing cloud computing networks against internal and external threats**, especially because traditional perimeter-based security is not suitable for modern cloud and hybrid environments. They conducted a **comparative review of existing Zero Trust models, frameworks, and proof-of-concept approaches** and categorized their features to understand which technologies can provide better security for cloud networks. The paper discusses technologies and methods such as **identity management, access control, trust evaluation, micro-segmentation, Software-Defined Perimeter (SDP), behaviour tracking, automated threat response, workload identity, and policy-based enforcement**. The authors reviewed different cloud environments including **public, private, and hybrid cloud infrastructures**, and compared existing Zero Trust approaches based on different security features and requirements. The review found that Zero Trust can improve **visibility, granular access control, identity verification, trust calculation, security automation, and threat response** in cloud environments. The paper also highlights important challenges such as **cloud architecture interoperability, weaknesses in perimeter-based security, virtualization vulnerabilities, insider threats, poor security practices, limited visibility, compliance issues, and difficulties in migrating existing systems to Zero Trust**. Since this is a comparative review, the results are mainly based on the analysis and comparison of existing research rather than a new experimental implementation. Therefore, this paper is **highly relevant to the ZeroTrustCloud project** because it provides a broad foundation for the project's planned identity-centric access control, cloud security, policy enforcement, continuous verification, security automation, monitoring, and Zero Trust implementation across cloud and hybrid environments.

Paper 5

Title: *Software Supply Chain Security in Cloud-Native Systems: A Zero Trust Framework for Securing APIs, Containers, Dependencies, and CI/CD Pipelines*

Authors: Santosh Kumar Jadala

Publication: *International Journal of Technology, Management and Humanities*, Volume 11, Issue 3, pp. 171–196

Publisher: International Journal of Technology, Management and Humanities

Paper Link: [Official Research Paper – International Journal of Technology, Management and Humanities](#)

Published: 2025

Review:

In this paper, the author addressed the problem of software supply chain attacks in cloud-native environments, where APIs, containers, open-source dependencies, build systems, and CI/CD pipelines are connected and can become targets for attackers. The author proposed a Zero Trust framework that applies continuous verification, least-privilege access, identity-based security, software provenance, artifact integrity checking, and policy enforcement throughout the software development and deployment lifecycle. The framework covers APIs, containers and Kubernetes workloads, third-party dependencies, source repositories, build systems, CI/CD pipelines, and runtime environments. The author used threat modeling, literature analysis, security-control mapping, and conceptual risk assessment rather than a real production dataset or experimental test environment. The framework shows improved security coverage across areas such as API security, container security, dependency security, CI/CD security, artifact provenance, identity verification, and continuous monitoring, while reducing risks such as dependency poisoning, credential theft, container tampering, repository compromise, and Kubernetes privilege abuse. However, the author identified limitations such as implementation complexity, additional performance and operational overhead, inconsistent SBOM quality, imperfect vulnerability detection, difficulty in designing strict Kubernetes policies, and the lack of real-world experimental validation because the framework is conceptual. Therefore, this paper is highly relevant to the **ZeroTrustCloud** project because it directly supports the project's planned identity management, least-privilege access, Kubernetes security, policy-as-code, workload verification, artifact signing, CI/CD security, supply chain protection, continuous monitoring, and automated policy enforcement.

Paper 6

Title: *Zero-trust based dynamic access control for cloud computing*

Authors: Ri Wang, Chen Li, Kun Zhang, Bibo Tu

Publication: *Cybersecurity*, Volume 8, Article 12

Publisher: Springer Nature

Paper Link: [Official Research Paper – Springer Nature](#)

Published: 2025

Review:

In this paper, the authors addressed the problem of traditional access control methods in cloud computing, which are not flexible enough to handle changing users, resources, threats, and cloud environments. They proposed a Zero Trust based dynamic access control system called **DR-TBAC**, which continuously evaluates the trustworthiness of users and dynamically changes access permissions. The approach combines a **Trust-Based Access Control (TBAC)** model with **LSTM** for analysing user behaviour and **Deep Q-Network (DQN)** reinforcement learning for dynamically updating trust thresholds and access control rules. The authors used the **OpenStack cloud environment** and an open-source OpenStack log dataset containing more than one million log entries. They trained the trust assessment model using user behaviour and contextual information from the logs and then tested the system using OpenStack with one control node and one compute node. The results showed that DR-TBAC achieved better security authorization performance than the compared approaches, with **0.98 precision, 0.97 recall, and 0.98 F1-score**, and it provided a **19% increase in security authorization accuracy** compared with static RBAC. The paper also highlights challenges such as the computational overhead of reinforcement-learning approaches, the need for efficient policy processing, and the difficulty of adapting the approach to different cloud platforms and policies. Therefore, this paper is highly relevant to the **ZeroTrustCloud** project because it directly supports dynamic identity-based access control, continuous trust evaluation, least-privilege authorization, behavioural monitoring, automated policy updates, machine learning, and adaptive security decisions in cloud environments.

Paper 7

Title: *A Multi-Cloud Framework for Zero-Trust Workload Authentication*

Authors: Saurabh Deochake, Ryan Murphy, Jeremiah Gearheart

Publication: *arXiv*, Computer Science – Cryptography and Security

Publisher: arXiv

Paper Link: [Official Research Paper – arXiv](#)

Published: 17 October 2025

Review:

In this paper, the authors addressed the problem of using static and long-lived credentials for workload authentication in modern multi-cloud environments. These credentials can increase the risk of credential theft, data leakage, resource hijacking, and lateral movement. They proposed a Zero Trust workload authentication framework based on **Workload Identity Federation (WIF)** and **OpenID Connect (OIDC)**. The framework replaces permanent credentials with short-lived and cryptographically verified tokens. The main technologies used include **Kubernetes ServiceAccounts**, **OIDC**, **JWT**, **AWS IAM**, **AWS IRSA**, and **GCP Workload Identity Federation**. The framework follows Zero Trust principles such as continuous authentication and least-privilege access. It supports secure workload authentication across **AWS**, **GCP**, and **Azure**. The authors implemented and validated the framework in a large enterprise environment. The environment contained more than **100 Kubernetes clusters** and hundreds of thousands of cloud resources. Kubernetes Bound Service Account Token Volumes were used to provide short-lived, audience-bound tokens. The cloud IAM systems then verified these tokens and issued temporary native credentials. The results showed that thousands of long-lived credentials could be replaced with on-demand federated tokens. The average credential lifetime was reduced to **under 60 minutes**. The approach also reduced the estimated access-control audit effort by approximately **80%**. It helped reduce risks related to leaked credentials and third-party credential compromise. The authors identified challenges such as extending the framework to additional cloud providers and improving dynamic authorization. They suggested future work involving **ABAC** and **Just-in-Time (JIT) credential issuance**. Therefore, this paper is highly relevant to the **ZeroTrustCloud** project because it directly supports **IAM**, **Kubernetes workload identity**, **multi-cloud security**, **workload identity federation**, **least privilege**, **ABAC**, **JIT access**, and **Zero Trust verification**.

Paper 8

Title: *Establishing Workload Identity for Zero Trust CI/CD: From Secrets to SPIFFE-Based Authentication*

Authors: Surya Teja Avirneni

Publication: *arXiv*, Computer Science – Cryptography and Security

Publisher: arXiv

Paper Link: [Official Research Paper – arXiv](#)

Published: April 2025

Review:

In this paper, the author addressed the problem of using **static secrets, shared service accounts, and platform-dependent credentials** in CI/CD pipelines, which can lead to credential leakage, privilege escalation, cross-tenant access, and software supply chain attacks. The author proposed a **SPIFFE-based workload identity model** that provides runtime-issued and cryptographically verifiable identities for CI/CD jobs and deployed workloads. The main technologies used include **SPIFFE, SPIRE, OIDC, JWT-SVID, X.509-SVID, Kubernetes, mTLS, Open Policy Agent (OPA), and Cedar**. SPIRE performs node and workload attestation using information such as Kubernetes service accounts, container image hashes, namespaces, and host attributes before issuing a SPIFFE identity. The paper explains how these identities can be used for **CI job runners, deployment targets, and cross-domain or multi-cloud environments**. SPIFFE SVIDs can also be used with AWS STS to obtain short-lived cloud credentials without storing permanent secrets. The proposed approach provides **runtime identity, platform independence, federation, least-privilege access, mutual authentication, and better auditability**. It also reduces risks from credential leaks, privilege escalation, replay attacks, and compromised CI runners. The author identified challenges in existing OIDC approaches, including **policy sprawl, claim fragility, limited cross-cloud federation, lack of intent awareness, and platform dependency**. The paper further proposes using **OPA or Cedar** to convert verified workload identity into context-aware access decisions. Therefore, this paper is highly relevant to the **ZeroTrustCloud** project because it directly supports **workload identity, Kubernetes security, CI/CD pipeline security, policy-as-code, mTLS, workload attestation, least privilege, multi-cloud federation, and continuous Zero Trust verification**.

Paper 9

Title: *Extending Kubernetes for Pods Integrity Verification*

Authors: Francesco Zaritto, Enrico Bravi, Silvia Sisinni, Antonio Lioy

Publication: *Journal of Network and Systems Management*, Volume 34, Article 14

Publisher: Springer Nature

Paper Link: [Official Research Paper – Springer Nature](#)

Published: 25 October 2025

Review:

In this paper, the authors addressed the problem of verifying the integrity of applications running as Kubernetes Pods in cloud environments, where tenants have limited control and visibility over infrastructure managed by cloud providers. They proposed a **remote attestation architecture** that extends Kubernetes to continuously verify the integrity of Pods and their underlying worker nodes. The main technologies used include **Kubernetes, Trusted Platform Module (TPM) 2.0, Integrity Measurement Architecture (IMA), Remote Attestation, cryptographic hashing, Custom Resource Definitions (CRDs), and Keylime concepts**. The authors created a new **IMA-cgpath template** to identify container and Pod activities and developed components such as the Registrar, Agent, Verifier, Worker Handler, Pod Handler, and Cluster Status Controller. The system was tested using a Kubernetes cluster with **two Intel NUC devices**, TPM 2.0, Ubuntu 22.04, and Debian 12 with a patched Linux kernel. The results showed that the system could verify Pod integrity within acceptable time limits and used about **10% less CPU than Keylime when comparing 40 Pods with one node**. Attestation of one Pod took **1.25 seconds**, compared with 2.6 seconds for Keylime to attest one node. The authors identified challenges such as the need for a patched Linux kernel, virtual TPM security, manual whitelist management, and the need to automate periodic attestation and remediation. Therefore, this paper is highly relevant to the **ZeroTrustCloud** project because it directly supports **continuous verification, Kubernetes workload integrity, workload attestation, runtime monitoring, trust evaluation, automated remediation, and cloud-native Zero Trust security**.

Paper 10

Title: *Zero Trust Segmentation for Cloud-Native and AI Service Architectures: An Intelligent Policy Enforcement Framework to Minimize Lateral Movement*

Authors: Navaneeth Komirisetty

Publication: *International Journal of Intelligent Systems and Applications in Engineering*, Volume 14, Issue 1s, Pages 615–626

Publisher: International Journal of Intelligent Systems and Applications in Engineering (IJISAE)

Paper Link: [Official Research Paper – IJISAE](#)

Published: 2026

Review:

In this paper, the author addressed the problem of **lateral movement in cloud-native and AI-enabled environments**, where traditional perimeter security cannot adequately protect internal service-to-service communication. The paper proposed a **Layered Zero Trust Segmentation Model (LZTSM)** that divides security controls into identity, network, workload, and data planes. The approach uses **Kubernetes workload identity, SPIFFE/SPIRE, Network Policies, service mesh, mTLS, and Open Policy Agent (OPA)** for enforcing security policies. It follows Zero Trust principles such as explicit verification, least privilege, assuming breach, and continuous evidence generation. The framework uses **explicit allow-listing** to control communication between services and prevent unauthorized lateral movement. It also separates the **Policy Decision Point (PDP)** from the **Policy Enforcement Point (PEP)** to support centralized policy management and enforcement. The paper considers **Kubernetes cloud-native environments and AI service architectures** containing model endpoints, retrieval systems, vector databases, and tool integrations. AI-specific risks such as **prompt injection, sensitive information disclosure, excessive agency, and vector-store weaknesses** are also considered. The proposed controls were evaluated by mapping the architecture against **NIST SP 800-207 Zero Trust principles** and related security frameworks. The paper shows that segmentation can provide stronger workload isolation, controlled communication, continuous monitoring, and improved visibility. It also recommends collecting network-flow logs, policy decisions, workload identities, and audit information for security investigation and compliance. The main challenges include managing large numbers of allow-list policies, dependency on workload identity infrastructure, and difficulties with legacy authentication systems. Future work focuses on **automating policy generation and improving AI-specific monitoring**. Therefore, this paper is highly relevant to the **ZeroTrustCloud project** because it directly supports **Kubernetes security, identity-centric access control, policy-as-code, service mesh security, micro-segmentation, continuous verification, observability, and automated Zero Trust policy enforcement**.